

AWS Zero To Hero - Week 2, Day 4

AWS Organizations, SCPs and IAM Identity Center - Student Guide

Learning notes, Draw.io architecture, tested practical and Week 2 repository assignment

Day 4 Focus

Today we learn how companies centrally manage multiple AWS accounts, group accounts with OUs, apply SCP guardrails, provide workforce access with IAM Identity Center, use temporary STS role sessions, and simplify billing through consolidated billing.

Code Meaning

Code	Meaning
D1-30%	SAA-C03 Domain 1 - Design Secure Architectures (30%)
D4-20%	SAA-C03 Domain 4 - Design Cost-Optimized Architectures (20%)
P1	Operational Excellence
P2	Security
P5	Cost Optimization

Topics Covered

AWS Organizations structure - D1-30% | P2,P1 | Best Practice: separate workloads by account and manage centrally

Organizational Units (OUs) - D1-30% | P2,P1 | Best Practice: group by environment or common controls

Service Control Policies (SCPs) - D1-30% | P2,P1 | Best Practice: test guardrails in a dedicated OU

IAM Identity Center - D1-30% | P2,P1 | Best Practice: MFA, groups and least-privilege permission sets

Cross-account access - D1-30% | P2,P1 | Best Practice: roles and STS temporary credentials

Consolidated billing - D4-20% | P5,P1 | Best Practice: central payer and linked-account cost visibility

Learning Outcomes

- Explain why companies use multiple AWS accounts.
- Identify the organization Root, management account, member account and OU.
- Explain why an SCP is a guardrail and not a permission grant.
- Use IAM Identity Center and verify the temporary role session with AWS STS.
- Demonstrate S3 access before and after an OU-level SCP becomes applicable.
- Explain consolidated billing and linked-account cost visibility.
- Create the Week 2 repository folder without exposing sensitive information.

Core Story in Simple Words

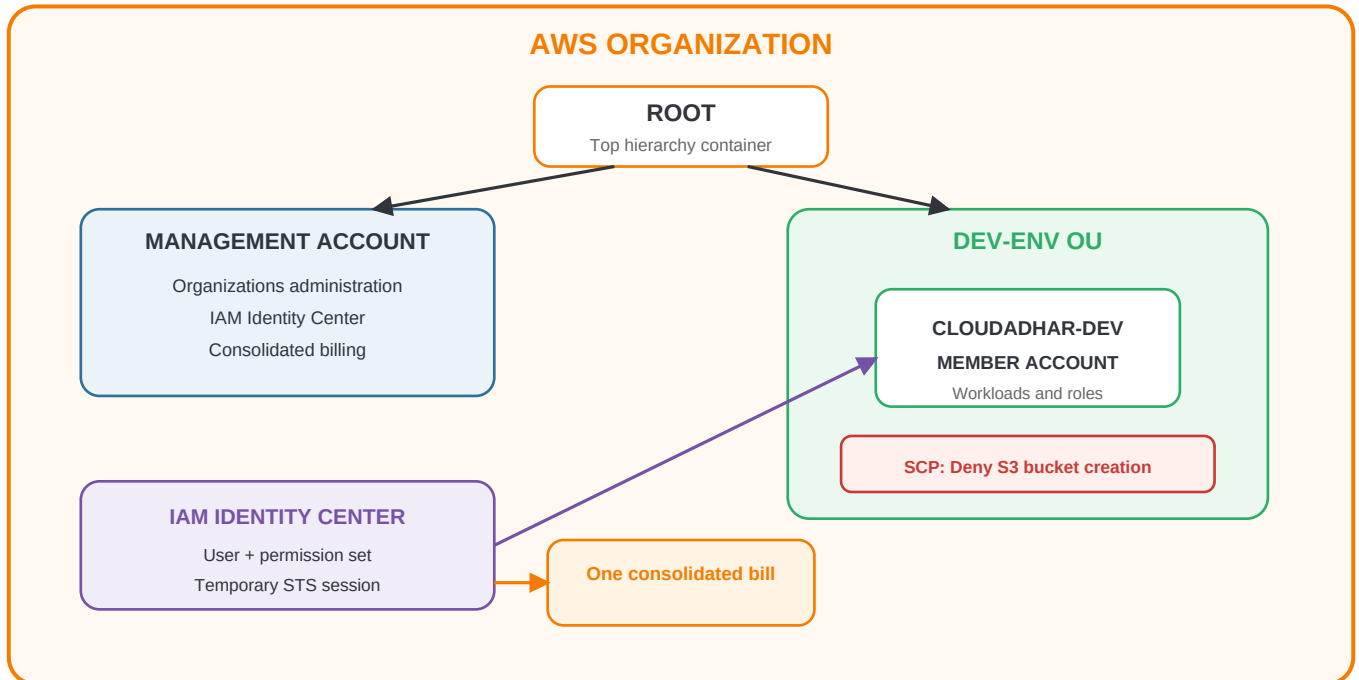
Remember this

A growing company separates workloads into multiple AWS accounts. AWS Organizations centrally governs those accounts. OUs group accounts, SCPs set maximum-permission guardrails, IAM Identity Center provides central workforce access, STS creates temporary sessions, and the management account receives the consolidated bill.

Which Well-Architected pillar?

Primary: P2 Security, because accounts create isolation boundaries, SCPs apply permission guardrails and Identity Center centralizes access. **Secondary: P1 Operational Excellence**, because governance is managed centrally. Consolidated billing primarily maps to **P5 Cost Optimization**.

Reference Architecture



The live demo starts with the member account directly under Root. It is moved into Dev-Env only after the successful before-SCP test.

Key Concepts

Concept	Meaning
AWS Organization	A collection of AWS accounts centrally managed together.
Organization Root	The top container in the hierarchy. It is not the AWS account root user.
Management account	Creates and administers the organization and pays member-account charges.
Member account	An AWS account in the organization that normally contains workloads.
Organizational Unit	A logical group of accounts that inherit common policy-based controls.
Service Control Policy	A guardrail that limits maximum available permissions. It does not grant access.
Permission set	An access definition provisioned by IAM Identity Center into assigned AWS accounts.

Additional Key Concepts

Concept	Meaning
AWSReservedSSO role	An IAM role created and managed by IAM Identity Center when a permission set is assigned.
OrganizationAccountAccessRole	A cross-account administration role created automatically when Organizations creates a member account.
AWS STS session	Temporary credentials issued after a role is assumed.
Consolidated billing	The management account pays and views charges for member accounts.

AWS Best Practices for Day 4

Topic	Best practice	Pillar
AWS Organizations	Use a multi-account strategy as workloads grow. Keep normal application workloads out of the management account.	P2, P1
OUs	Group accounts by function, environment, compliance need or common controls - not the reporting hierarchy.	P2, P1
SCPs	Treat SCPs as maximum-permission guardrails. Test in a dedicated OU before wider rollout.	P2, P1
IAM Identity Center	Centralize workforce access. Use MFA, groups and least-privilege permission sets.	P2, P1
Cross-account access	Use trusted roles and STS temporary credentials instead of duplicate IAM users and shared keys.	P2, P1
Consolidated billing	Track cost by linked account, create budgets and keep payer/admin duties in the management account.	P5, P1

Important

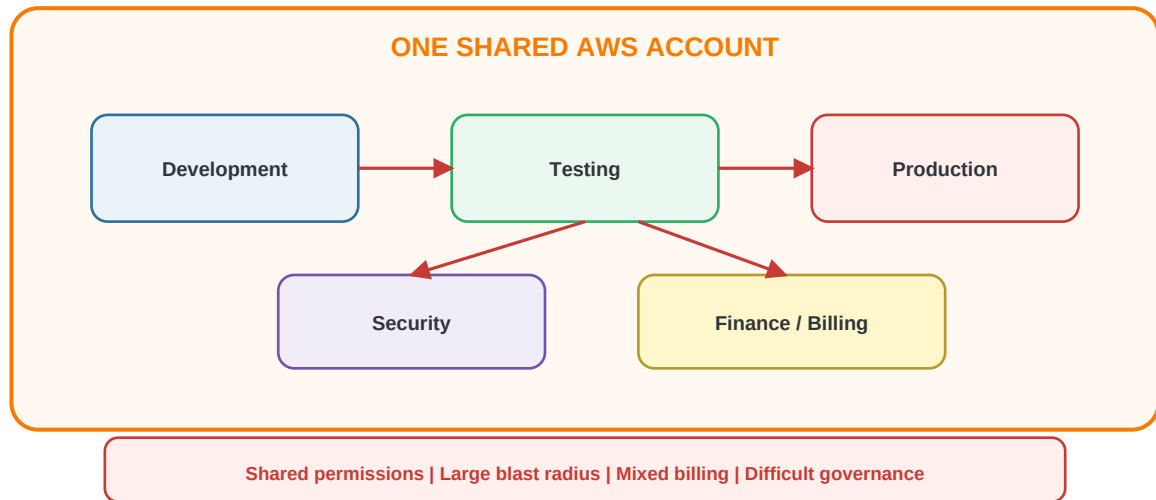
An SCP does not give access. IAM policies or IAM Identity Center permission sets grant access. The SCP defines the maximum permissions available to affected identities in member accounts. SCPs do not restrict users or roles in the management account.

Management account best practice

Use the management account only for tasks that must be performed there: Organizations administration, selected centralized security services, IAM Identity Center administration and consolidated billing. Place normal workloads in member accounts.

Multi-account problem - D1-30% | P2,P1 | Best Practice: isolate development, testing and production using separate accounts

Draw.io Exercise 1 - Show the One-Account Problem

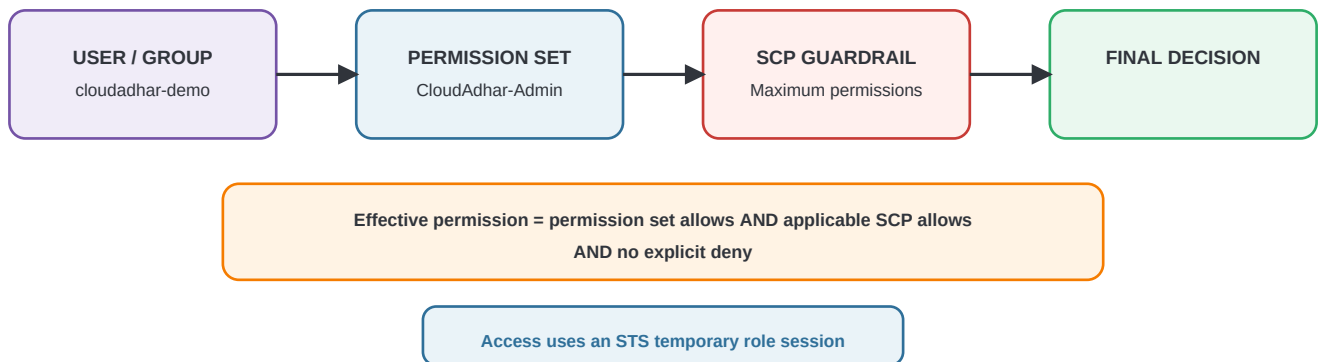


- Create a blank landscape diagram.
- Add one large rounded rectangle named ONE SHARED AWS ACCOUNT.
- Inside it, add Development, Testing, Production, Security and Finance / Billing.
- Add red arrows to show that actions in one area can affect another.
- Add the risk statement: Shared permissions | Large blast radius | Mixed billing | Difficult governance.
- Save the page as 1 - One Account Problem.

Draw.io Exercise 2 - Build the AWS Organizations Architecture

- Create a second page named 2 - AWS Organizations Architecture.
- Add a large container called AWS ORGANIZATION.
- At the top, add ROOT.
- Under Root, add MANAGEMENT ACCOUNT on the left and DEV-ENV OU on the right.
- Inside Dev-Env, add CLOUDADHAR-DEV MEMBER ACCOUNT.
- Attach a red SCP box to the OU: Deny S3 bucket creation.
- Add IAM IDENTITY CENTER on the lower left and connect it to both accounts.
- Add One consolidated bill below the management account.
- For the live demo, show the member account under Root first and move it into Dev-Env later.

Draw.io Exercise 3 - Permission and STS Flow



- Create a third page named 3 - Permission and STS Flow.
- Draw User / Group -> Permission Set -> SCP Guardrail -> Final Decision.
- Add the permission formula shown in the diagram.
- Add: Access is delivered through an STS temporary role session.
- Add two role labels: AWSReservedSSO_... and OrganizationAccountAccessRole.

Repository diagram folder

Save the editable diagram as **week2/day-04-aws-organizations/diagrams/aws-organizations-architecture.drawio**. Export masked PNG copies for the repository screenshots or documentation.

Practical Prerequisites

- A dedicated learning AWS Organization with all features enabled.
- One management account and one pre-created member account named CloudAdhar-Dev.
- The member account must be directly under Root before the first S3 test.
- An empty Dev-Env OU with Deny-S3-Bucket-Creation already attached.
- IAM Identity Center organization instance enabled in ap-south-1.
- cloudadhar-demo user with MFA and CloudAdhar-Admin permission set.
- Identity Center assignment to both the management and member accounts.
- Normal browser for management, incognito for the portal, and a separate Dev console window.

Security rule

Mask account IDs, email addresses, organization IDs, OU IDs, portal URLs and full role ARNs in screenshots. Never commit access keys, secret keys, session tokens or MFA QR codes.

AWS Organizations + OUs - D1-30% | P2,P1 | Best Practice: central governance + common controls

Practical Part 1 - Build the Organization Structure

A. Create the organization

- Sign in to the dedicated management account.
- Open AWS Organizations and choose Create an organization.
- Confirm all features are enabled and Root is created automatically.
- The current account becomes the management account.

B. Create the member account

- Open AWS Organizations -> AWS accounts -> Add an AWS account -> Create an AWS account.
- Name it CloudAdhar-Dev and use a unique, unused email address.
- Keep the IAM role name OrganizationAccountAccessRole.
- Wait until the account is active and keep it directly under Root.

C. Create the OU

- Select Root -> Actions -> Organizational unit -> Create new.
- Create Dev-Env.
- Do not move CloudAdhar-Dev yet.

D. Create and attach the SCP

- Open Policies -> Service control policies and confirm SCPs are enabled.
- Create Deny-S3-Bucket-Creation using the JSON below.
- Attach it to the empty Dev-Env OU.
- Keep FullAWSAccess attached.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyS3BucketCreation",
      "Effect": "Deny",
      "Action": "s3:CreateBucket",
      "Resource": "*"
    }
  ]
}
```

Expected result

Root contains the management account and CloudAdhar-Dev. Dev-Env is empty and has FullAWSAccess plus Deny-S3-Bucket-Creation attached. The custom deny does not affect the member account yet.

IAM Identity Center - D1-30% | P2,P1 | Best Practice: MFA + permission sets + temporary access

Practical Part 2 - Configure IAM Identity Center

A. Enable the organization instance

- From the management account, select Asia Pacific (Mumbai) - ap-south-1.
- Open IAM Identity Center and choose Enable.
- Use an Organization instance and the AWS owned encryption key.

B. Create the user

- Open Users -> Add user.
- Create cloudadhar-demo using an email address you can access.
- Complete password activation and register MFA before class.

C. Create the permission set

- Open Multi-account permissions -> Permission sets -> Create permission set.
- Choose Predefined permission set -> AdministratorAccess.
- Name it CloudAdhar-Admin and use a one-hour session duration.

D. Assign account access

- Assign cloudadhar-demo with CloudAdhar-Admin to CloudAdhar-Management.
- Assign the same user and permission set to CloudAdhar-Dev.
- Wait until provisioning completes.

E. Test the AWS access portal

- Open the AWS access portal in an incognito browser.
- Sign in as cloudadhar-demo and complete MFA.
- Confirm that both CloudAdhar-Management and CloudAdhar-Dev are visible.
- Open CloudAdhar-Dev -> CloudAdhar-Admin -> Management Console.
- Select Mumbai, open CloudShell and run the command below.

```
aws sts get-caller-identity
```

Expected result

The Account value is the member-account ID. The ARN contains assumed-role/AWSReservedSSO_CloudAdhar-Admin_.../cloudadhar-demo. This proves Identity Center and STS temporary access are working.

Portal shows zero accounts?

Creating a user or permission set alone is not enough. Verify the user/account/permission-set assignment and wait for provisioning to complete.

SCP guardrail - D1-30% | P2,P1 | Best Practice: prove access before and after OU inheritance

Practical Part 3 - Prove the SCP Guardrail

A. Before-SCP test: member account is under Root

```
export AWS_REGION=ap-south-1

ACCOUNT_ID=$(aws sts get-caller-identity \
  --query Account \
  --output text)

BUCKET="cloudadhar-before-scp-${ACCOUNT_ID}-${date +%s}"

echo "$BUCKET"

aws s3api create-bucket \
  --bucket "$BUCKET" \
  --region "$AWS_REGION" \
  --create-bucket-configuration LocationConstraint="$AWS_REGION"
```

Expected result

The bucket is created because the role has AdministratorAccess and CloudAdhar-Dev is still under Root. The SCP attached to Dev-Env is not applicable yet.

Delete the test bucket

```
aws s3api delete-bucket \
  --bucket "$BUCKET" \
  --region "$AWS_REGION"

aws s3api head-bucket --bucket "$BUCKET"
```

Expected verification: **404 Not Found**.

B. Move the member account into Dev-Env

- Return to the management account.
- Open AWS Organizations -> AWS accounts.
- Select CloudAdhar-Dev -> Actions -> AWS account -> Move.
- Choose Dev-Env and confirm Move AWS account.
- Do not choose Close, Remove from organization or Leave organization.

Safety

Move changes the account position in the hierarchy. Close shuts down the account. Remove makes it leave the organization. For this demo, use only Actions -> AWS account -> Move.

Practical Part 3 - Prove the SCP Guardrail (continued)

C. After-SCP test: member account is inside Dev-Env

```
aws sts get-caller-identity

ACCOUNT_ID=$(aws sts get-caller-identity \
  --query Account \
  --output text)

BUCKET="cloudadhar-after-scp-${ACCOUNT_ID}-${date +%s}"

echo "$BUCKET"

aws s3api create-bucket \
  --bucket "$BUCKET" \
  --region ap-south-1 \
  --create-bucket-configuration LocationConstraint=ap-south-1
```

Expected result

AccessDenied with the message **explicit deny in a service control policy**. The permission set still allows the operation, but the OU-level SCP sets the maximum available permission and the explicit deny wins.

Permission Rule

```
Effective permission =
Permission set or IAM policy allows
AND applicable SCP allows
AND no explicit deny
```

Cross-account access - D1-30% | P2,P1 | Best Practice: role-based temporary access

Practical Part 4 - Show the Two Role Patterns

- Inside CloudAdhar-Dev, open IAM -> Roles.
- Find AWSReservedSSO_CloudAdhar-Admin_... . This role is created and managed by IAM Identity Center.
- Find OrganizationAccountAccessRole. This role is created automatically when AWS Organizations creates the member account.
- Both role patterns use AWS STS temporary credentials.
- If an existing account was invited instead of created, OrganizationAccountAccessRole is not created automatically and must be added manually if required.

Role	Purpose
AWSReservedSSO_...	Workforce user access from IAM Identity Center and the AWS access portal.
OrganizationAccountAccessRole	Management-account-to-member-account administrative access.

EC2 metadata reminder

EC2 instance metadata uses 169.254.169.254 from inside the EC2 instance. Do not use the instance public or private IP. This Organizations practical verifies identity with `aws sts get-caller-identity`.

Consolidated billing - D4-20% | P5,P1 | Best Practice: linked-account reporting + budgets + central payer

Practical Part 5 - Consolidated Billing

- Return to CloudAdhar-Management.
- Open Billing and Cost Management -> Bills.
- Review Charges by account when data is available.
- Open Cost Explorer and choose Group by -> Linked account.
- Explain that new usage may take time to appear.

Benefit	Explanation
One bill	The management account pays the charges generated by member accounts.
Easy tracking	Costs and usage can be reviewed across the organization and by linked account.
Combined eligible usage	Some tiered pricing and discount benefits can apply across combined usage.
No extra fee	AWS Organizations consolidated billing has no separate additional fee.

Common Mistakes and Fixes

Mistake	Fix
Testing the SCP in the management account	SCPs affect member accounts, not management-account users or roles.
Removing FullAWSAccess	Keep it attached for this deny-list lab.
Attaching an untested SCP to Root	Attach it to a dedicated test OU first.
Bucket creation fails before the move	Check the correct member account, unique bucket name, region and LocationConstraint.
Portal shows zero accounts	Create the account assignment: user/group + AWS account + permission set.
Using Close instead of Move	Use Actions -> AWS account -> Move. Do not close the account during cleanup.
Using Remove from organization	Move the account back to Root; do not remove it for routine reset.

Class reset

After rehearsal, move CloudAdhar-Dev back to Root. Keep Dev-Env, the SCP, Identity Center user, permission set and account assignments. Confirm there are no test S3 buckets.

Week 2 Repository Folder

Repository objective

Store today's notes, tested commands, SCP JSON, diagrams and masked evidence in a clean Week 2 folder. The repository must contain no account-specific secrets or unmasked identifiers.

Recommended Structure

```
week2/
|-- README.md
|-- day-03-iam-roles-sts/
|   |-- README.md
|-- day-04-aws-organizations/
|   |-- README.md
|   |-- practical/
|       |-- 01-complete-demo-runbook.md
|       |-- 02-identity-center-setup.md
|       |-- 03-consolidated-billing.md
|   |-- policies/
|       |-- deny-s3-bucket-creation.json
|   |-- diagrams/
|       |-- aws-organizations-architecture.drawio
|   |-- screenshots/
|       |-- organization-tree-masked.png
|       |-- identity-center-accounts-masked.png
|       |-- sts-identity-masked.png
|       |-- s3-before-scp-success.png
|       |-- s3-after-scp-access-denied.png
```

README.md Must Include

- Today's Learning Focus.
- Topics Covered with SAA-C03 domain and Well-Architected pillar mapping.
- Concepts in simple words.
- The complete demo story: Root success -> move to OU -> SCP denial.
- The effective-permission rule.
- Learning outcomes, prerequisites, cleanup and safety notes.
- Links to the practical guides, SCP JSON and Draw.io diagram.

Student Repository Assignment

- Explain every component in your own words.
- Include the before-and-after SCP test result.
- Explain IAM Identity Center permission sets and temporary STS access.
- Explain the difference between an IAM permission and an SCP guardrail.
- Explain AWSReservedSSO_... vs OrganizationAccountAccessRole.
- Mask all sensitive values before pushing to GitHub.

Never upload

Root email, account IDs, access keys, secret keys, session tokens, MFA QR codes, Organization ID, portal URL, payment information or complete assumed-role ARNs.

Cleanup and Final Checklist

- Delete the successful before-SCP test bucket.
- The after-SCP bucket does not exist because creation was denied.
- Move the active member account back to Root after rehearsal.
- Do not close the member account as normal lab cleanup.
- Keep Dev-Env and the SCP ready for the live demonstration.
- Keep Identity Center user, MFA, permission set and both account assignments ready.
- Before every terminal command, run `aws sts get-caller-identity`.
- Use separate browser windows labelled MANAGEMENT, DEV and PORTAL.

Official AWS References

Reference	Official AWS URL
R1 - AWS Organizations introduction	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_introduction.html
R2 - Organization concepts	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_getting-started_concepts.html
R3 - Create and manage OUs	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_ous.html
R4 - Move accounts between Root and OUs	https://docs.aws.amazon.com/organizations/latest/userguide/move_account_to_ou.html
R5 - Service control policies	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html
R6 - Create member accounts	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_accounts_create.html
R7 - Access member accounts	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_accounts_access.html
R8 - IAM Identity Center overview	https://docs.aws.amazon.com/singlesignon/latest/userguide/what-is.html
R9 - Organization instances	https://docs.aws.amazon.com/singlesignon/latest/userguide/organization-instances-identity-center.html
R10 - Permission sets	https://docs.aws.amazon.com/singlesignon/latest/userguide/permissionsets.html
R11 - Configure AWS account access	https://docs.aws.amazon.com/singlesignon/latest/userguide/manage-your-accounts.html
R12 - Consolidated billing	https://docs.aws.amazon.com/awsaccountbilling/latest/aboutv2/consolidated-billing.html
R13 - Security Pillar account separation	https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/aws-account-management-and-separation.html

Verification note

Content and console flow were updated after a successful before-and-after SCP practical and checked against official AWS documentation on 12 July 2026. Console labels may change slightly; follow the service concepts and permission model.